

Cloud-Native Ransomware in Object Storage response

Ransomware · **Critical** severity · SOC IR Playbook

Incident type	Ransomware - Object Storage (Cloud-native)
Severity	Critical
Priority	Critical
Detection sources	CSPM Alerts, SIEM, Cloud Storage Logs, CASB, CloudTrail, Access Analyzer, User Reports

Scenario

An attacker gains access to cloud object storage (e.g., Amazon S3, Azure Blob Storage, Google Cloud Storage) and performs malicious actions such as encrypting files, altering permissions, deleting backups or placing ransom notes - without deploying ransomware binaries, purely using APIs or SDKs.

MITRE ATT&CK

T1485, T1486, T1531

Preparation

Apply strict IAM policies Use least privilege principles for storage access (read/write/delete) Enable versioning and MFA delete In S3, GCS or Azure Blob to retain file history and block unauthorised deletes Enable logging and monitoring CloudTrail, Storage Access Logs and alerting on anomalous activity Set up anomaly detection for storage Sudden write/delete bursts, non-human behaviour, large-scale file access Test restoration processes Ensure backups and snapshots can be restored quickly and reliably

Detection & Analysis

Alert triggered Unusual storage activity: mass object overwrites/deletions, access from unknown IPs or ransom note files Correlate with IAM activity Identify user or service account responsible for the storage operations Determine extent of impact Number of buckets/containers, types of data affected and presence of backups Search for IOCs Files renamed/encrypted, ransom notes (e.g., README_TO_RESTORE.txt), strange file extensions

Containment

Revoke affected IAM roles or keys Immediately disable access for the user or application responsible Block malicious IP addresses Using CSP firewall rules or geofencing Lock down storage buckets Remove public access and apply restrictive ACLs and policies Alert cloud security and incident response team Trigger emergency remediation plan

Eradication

Audit all storage policies and access logs Ensure no other backdoors or malicious users remain active Rotate access credentials For all cloud accounts and applications involved Remove attacker implants or files Delete ransom notes, trojaned files or API logs left behind Patch external entry points If exploitation came via web app or exposed access key

Recovery

Restore from backup or object versioning Use last known good versions or automated snapshots Verify data integrity Check that restored files are complete and unaltered Resume business services After storage and applications are validated safe Increase logging and detection thresholds For affected buckets and linked identities

Lessons Learned & Reporting

Conduct RCA Trace attack vector, methods used and timeline Improve monitoring and access controls Enforce stricter policies on object storage access and anomaly detection Update runbooks and alert rules Include new attack patterns and prevention guidance Train DevOps and cloud admins On secure storage configurations and

rapid response techniques Report incident To regulatory bodies and customers if sensitive data was affected

Tools typically involved

Cloud Audit Logs (e.g., AWS CloudTrail, Azure Activity Logs, GCP Admin Logs); CSPM Tools (e.g., Wiz, Prisma Cloud, Microsoft Defender for Cloud); SIEM (e.g., Sentinel, Splunk, Chronicle); CASB (e.g., Netskope, Defender for Cloud Apps); Backup and DR Tools (e.g., AWS Backup, Azure Site Recovery, GCP Snapshots); SOAR (for auto-remediation)

Success metrics (SLA targets)

Detection Time <5 minutes from mass storage modification IAM Key Revocation Time <10 minutes from detection Data Restoration Time <6 hours (for critical data) Access Policy Review Time 100% of affected buckets reviewed within 24 hours RCA and Remediation Report Completed within 72 hours